

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

VERBALE DI ESERCITAZIONE TABLETOP NIS2

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-MOD183_00	00	29/04/2026	4
Redatto da	Approvato da	Classificazione	Stato
RSGI	AD – Francesco Epifani	Riservato Alta Direzione	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
29/04/2026	29/04/2026	29/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

1. Scopo

Il presente modulo formalizza il verbale dell'esercitazione di simulazione di incidente significativo (tabletop exercise) prevista dalla TD-SGI-PRO070_00 §6, almeno una volta all'anno. L'esercitazione mette alla prova la catena di risposta a 5 fasi, le tempistiche di notifica T0+24h/72h/30gg, il coordinamento fra i ruoli SGI e l'efficacia dei moduli MOD181, MOD182, MOD184 e IDL026.

Il verbale è redatto dal RSIG, sottoscritto dal Punto di Contatto NIS e approvato dall'Alta Direzione, e costituisce evidenza opponibile in audit ACN e ISO/IEC 27001.

2. Anagrafica esercitazione

Voce	Dato
Identificativo	TBL-NIS-yyyy-##
Data e ora di svolgimento	gg/mm/aaaa, hh:mm – hh:mm
Sede	[Sede aziendale / Sala Riunioni / Modalità remota]
Durata effettiva	[hh:mm]
Tipologia	Tabletop / Functional / Full-scale
Frequenza prevista	1/anno (PRO070 §6)
Allegati	Scenario, slide kick-off, log decisioni, eventuale registrazione

3. Partecipanti

Ruolo	Nominativo	Presente (S/N)	Modalità (presenza/remoto)
AD / Legale Rappresentante (PdC NIS)	Francesco Epifani	S	Presenza
RSIG (sostituto PdC NIS)	Iacopo Cupelli	S	Presenza
IT Manager	Francesco Epifani	S	Presenza
DPO	Avv. Claudia Del Re	S	Remoto
Direttore Sanitario	Prof. Gian Luigi Taddei	S	Presenza
Direttore Laboratorio	Prof. Gian Luigi Taddei	S	Presenza
RSPP	Iacopo Cupelli	S	Presenza
Membro OdV 231 (osservatore)		S	Presenza
Comunicazione/Marketing (osservatore)	Silvia Sansoni	S	Presenza

4. Scenario di esercitazione

Lo scenario è definito a cura del RSIG in coordinamento con l'IT Manager e mantenuto riservato fino all'apertura dell'esercitazione. Tipologie ricorrenti per Toscana Diagnostica:

Scenario	Trigger	Sistemi coinvolti	Esito atteso
Ransomware su LIS	Cifratura selettiva del database LIS in fascia notturna	LIS + backup + middleware IVD	Attivazione catena 5 fasi, contenimento e notifica T0+24h
Esfiltrazione referti	Login anomalo + download massivo da portale referti	Portale refertazione + AD	Identificazione data breach GDPR + notifica ACN + Garante

Compromissione fornitore datacenter	MSSP segnala intrusione presso datacenter primario	Datacenter + servizi NIS-soggetti	Attivazione clausole supply-chain, escalation NIS2
DDoS su portale paziente	Indisponibilità servizio refertazione esterna	Portale paziente + DNS	Verifica significatività, notifica conferma o conferma-non-significativo
Phishing al personale amministrativo	Furto credenziali con propagazione AD	AD + mail + LIS in pivot	Verifica MFA, contenimento credenziali, notifica significativa

5. Iniezioni temporali (timeline esercitazione)

T	Iniezione	Decisione richiesta	Risposta del team	Tempo di risposta
T0	Allerta SOC al PdC NIS	Apertura formale incidente	[testo libero]	[hh:mm]
T0+30'	Estensione del perimetro a 2° sistema	Riconfigurazione catena di risposta		
T0+1h	Identificazione primi indicatori di esfiltrazione	Decisione data-breach SI/NO		
T0+2h	Richiesta info da reparto clinico	Comunicazione interna verso DS		
T0+4h	Decisione sulla notifica al Garante	Formalizzazione notifica art. 33 GDPR		
T0+8h	Stesura bozza notifica T0+24h ACN	Approvazione PdC NIS + AD		
T0+12h	Aggiornamento clinico al personale di laboratorio	Comunicazione operativa LIS down		
T0+24h	Trasmissione notifica preliminare CSIRT	Sottoscrizione PdC NIS		
T0+48h	Aggiornamento RCA preliminare	Decisione su comunicazione pubblico		
T0+72h	Trasmissione notifica intermedia	Sottoscrizione PdC NIS		

6. Osservazioni e Lessons Learned

[Compilare a cura del facilitatore/RSGI al termine dell'esercitazione. Annotare punti di forza, criticità rilevate, gap procedurali, gap tecnici, gap formativi.]

7. Azioni correttive (CAPA)

#	Gap rilevato	Azione correttiva	Owner	Scadenza	Stato
1	[descrizione gap]	[azione]	[ruolo]	[gg/mm/aaaa]	Aperto/Chiuso
2					
3					
4					
5					

8. Indicatori di efficacia

KPI	Target	Esito esercitazione
Rispetto della finestra T0+24h simulata	100%	
Rispetto della finestra T0+72h simulata	100%	
% partecipanti previsti effettivamente presenti	≥ 80%	
Numero di gap procedurali rilevati	Riferimento storico	
Tempo medio di apertura incidente da T0	≤ 30'	
Coerenza con la catena di responsabilità PRO070	100%	

9. Sottoscrizioni

RSGI (redattore)

Punto di Contatto NIS

AD (approvazione)

[nominativo]

AD – Francesco Epifani

AD – Francesco Epifani

Firma: _____

Firma: _____

Firma: _____

Data: ____/____/____

Data: ____/____/____

Data: ____/____/____

10. Storico delle revisioni

Rev.	Data	Descrizione	Redatto	Approvato
00	29/04/2026	Prima emissione del verbale di esercitazione tabletop NIS2 in attuazione di TD-SGI-PRO070_00 §6.	RSGI	AD